

AUDIT YOUR TEAMMATE'S WEEK 5 PROJECT

Teammate: Javier Portero

1. CHECKPOINTS

1.1. RECOGNIZE

I would classify Javier's project as limited-risk/transparency-risk AI. It does not fall within any prohibited practice under Article 5 nor qualifies as a high-risk AI system under Annex III, because it supports the applicant when generating his documents, and explicitly "does not rank applicants for an employer, reject candidates, or decide access to employment." Since the system uses generative AI to produce application materials and interact with users, transparency and awareness obligations (Article 50 of the Act) would apply. However, the applicant retains control over submissions and sensitive answers. Depending on deployment details, some components may also trigger GDPR concerns because the system processes sensitive personal data.

1.2. PROBE

1. Does the system ever evaluate, rank, score, shortlist, or recommend candidates for hiring decisions — either directly to employers/recruiters or indirectly through comparative scoring?

If the system materially influences recruitment decisions, for example by generating fit scores, recommending whether to apply, comparing candidates, or providing employer-facing assessments, it could move into the high-risk category.

Expected answer: No, the system appears purely applicant-assistive and does not perform employer-side candidate evaluation or decision support.

2. Is the browser automation ever configured to autonomously submit applications, answer employment-related questions without human confirmation, or interact with employers on the user's behalf?

The current description emphasizes human review and states the browser agent stops before submission. A fully autonomous employment-application agent could be viewed as exercising more consequential decision-making or profiling functions, especially where sensitive employment or equality-related fields are involved. It would also affect transparency, accountability, and human-oversight analysis under the Act.

Expected answer: The system remains human-in-the-loop, requires user review of all sensitive fields, and does not autonomously submit applications.

3. Are any sensitive or special-category inferences generated about the applicant (for example inferred ethnicity, health/disability status, personality traits, employability scores, or behavioral profiling), even if only for “optimization” purposes?

Expected answer: The system only processes user-provided data and does not infer protected traits, psychological profiles, or suitability scores beyond drafting and formatting assistance.

1.3. ROLES

1. Provider

The organization that offers the job-search system to the market, that is, the company (startup, consultancy...) operating the application under its name or trademark.

Key obligations:

- Transparency obligations under Article 50 for AI-generated content and user awareness.
- Provide clear instructions for use, limitations, and human-review requirements.
- Implement appropriate logging, monitoring, and incident handling.
- Maintain technical documentation sufficient to support the risk classification.
- Ensure GDPR-compliant processing of personal and potentially sensitive data.

2. Deployer

The end user operating the system for creating job applications (an individual applicant, recruiting coach, career service, or organization internally using the tool for candidates).

Key obligations:

- Use the system according to the provider's instructions.
- Maintain meaningful human oversight over generated application materials and sensitive fields.

3. Third-Party Vendor / Upstream Component: OpenAI

Acts as an upstream GPAI/model provider supplying foundation-model capabilities.

Key obligations:

- GPAI-model obligations under the AI Act (technical documentation, copyright-policy compliance, transparency duties, model information sharing with downstream providers, etc.).
- Not normally responsible for downstream employment-use compliance unless controlling the downstream system design or branding.

1.4. GAPS

The main likely obligation is under Article 50 transparency rules:

- Users should be informed they are interacting with or receiving content generated by AI, that is, the generated application materials (cover letters, recruiter messages, form answers, summaries) should be identifiable as AI-assisted/generated where relevant.
- Users should understand the system's role, limits, and need for human review.

Are they in place? Partially

The provided brief strongly emphasizes:

- Human review
- Editable outputs
- Manual confirmation
- No autonomous submission
- Explicit handling of sensitive fields

However, the brief does **not explicitly state**:

- That users are formally notified they are using an AI system (although it could be argued that it is noticeable from the context)
- That generated text is labeled AI-generated
- That disclosures/warnings are surfaced in the UI

2. AUDIT REPORT

2.1. SYSTEM SUMMARY

Job Search Automation is a Streamlit-based application that helps job applicants prepare and structure employment applications using generative AI. It processes CVs, candidate profiles, job URLs, and application pages to produce outputs such as cover letters, form-answer drafts, recruiter messages, and application checklists. It also supports browser-assisted form filling using reviewed “fill plans,” with human oversight required before submission. The system does not rank, score, or evaluate candidates for employers and does not autonomously submit applications. Human review remains central throughout the workflow.

2.2. RISK CLASSIFICATION: LIMITED-RISK / TRANSPARENCY-RELEVANT AI

The system does not engage in prohibited practices under Article 5 and does not qualify as high-risk under Annex III (employment) because it does not perform employer-side recruitment functions such as screening, ranking, or rejecting candidates. It operates as an applicant-side productivity tool supporting preparation of application materials. However, because it generates AI-assisted employment-related content and processes personal data, Article 50 transparency obligations apply. The classification would change if it were repurposed for employer-side candidate evaluation or if browser automation became autonomous.

2.3. ROLE MAP

- **Provider:** The entity deploying the system under its name (project team or organization). **Obligations:** AI transparency (Art. 50), instructions for use, technical documentation, logging, GDPR compliance, and ensuring correct intended use.
- **Deployer:** End user (job applicant or organization using it). **Obligations:** Human oversight, lawful use of personal data, review of outputs before submission.
- **GPAI Provider:** OpenAI. **Obligations:** Model-level transparency, documentation, and GPAI compliance duties under the AI Act.
- **Tooling providers:** Playwright, Streamlit, LangGraph. **Role:** Infrastructure only; no downstream AI Act obligations unless they market the integrated system.

2.4. COMPLIANCE FINDINGS

1. Transparency (Article 50)

AI-generated application materials and workflows are central to the system. While human review is strong, explicit user-facing disclosure and durable labeling of AI-generated outputs (especially in exports) are not confirmed.

- **Severity:** Significant
- **Action:** Add clear AI-use notices in UI and export metadata/labels.
- **Escalation:** Legal review (transparency scope).

2. GDPR / Personal Data Processing

The system processes CVs, identity data, work authorization, salary expectations, and potentially sensitive employment data. Data handling policies, retention rules, and deletion controls are not evidenced.

- **Severity:** Significant
- **Action:** Add privacy notice, data-flow mapping, retention/deletion controls, and security measures.
- **Escalation:** DPO/privacy counsel.

3. Browser Automation Risk

Browser-assisted form filling interacts with third-party job sites and may input personal data into live systems. Human-in-the-loop design reduces risk, but operational and terms-of-service risks remain.

- **Severity:** Significant
- **Action:** Add explicit user consent step, logging, and reinforced “no auto-submit” safeguards.
- **Escalation:** Legal/product review.

4. Human Oversight Controls

Human review, editable outputs, and sensitive-field blocking are well implemented. However, a formal approval state before browser execution is not fully defined.

- **Severity:** Minor
- **Action:** Introduce explicit approval stage before browser execution.
- **Escalation:** No.

2.5. OVERALL RECOMMENDATION: PROCEED WITH CONDITIONS

The system is classified as limited-risk because it supports applicant-side preparation and not than employer-side decision-making. Strong human oversight and controlled workflows are already in place. However, significant gaps exist in transparency labeling, GDPR documentation, and browser automation safeguards. These should be addressed before production deployment, especially if the system is commercialized or scaled.

2.6. DISCLAIMER

This report is a preliminary compliance assessment only and does not constitute legal advice, a conformity assessment, or certification under the EU AI Act. Final determinations should be validated with qualified legal counsel before deployment or market placement.

2.7. STRETCH - GDPR / DATA GOVERNANCE GAP (FINDING 2)

The GDPR-related compliance gap should be closed by establishing a clear privacy framework for all personal and sensitive data processed by the system, including CVs, job application data, and outputs generated via third-party AI models.

It should consist of a Data Protection Impact Assessment (DPIA), a system-level data flow diagram, and a short but formal data governance policy covering lawful basis, retention rules, deletion procedures, and third-party processing (including AI API usage). This pack should be complemented by a user-facing privacy notice that explicitly explains what data is collected, how it is processed, and when it is sent to external AI providers.

Responsibility should sit primarily with a Data Protection Officer or external privacy counsel, with support from the engineering lead to produce accurate system data flows and from the product owner to implement the required UI disclosures. Engineering is also responsible for implementing retention, deletion, and access control mechanisms, while product ensures the disclosures are correctly surfaced to users.

A realistic timeline is four weeks: the first week for technical data mapping, the second for DPIA drafting, the third for policy and privacy notice finalisation, and the fourth for implementation and validation of technical controls.

3. JOINT CLOSING NOTE

Auditing self-produced work facilitates understanding intent, system boundaries, and design choices, which helps with faster and more context-aware classification. However, that familiarity can also reduce rigor, as one may unconsciously accept assumptions or downplay gaps because you know how the system is “meant” to work. Auditing someone else’s system tends to be more structured and critical, but requires more effort to infer intent and reconstruct design context from limited information.